

CYBERSECURITY MATURITY & ISMS ASSESSMENT

SkyBridge Travel Services

NIST CSF 2.0 & ISO/IEC 27001:2022 Gap Assessment

Portfolio Assessment Report

Revised simulated assessment of six priority cybersecurity control areas

Prepared as a fictional, non-certification assessment

1. Executive Summary

This assessment evaluates the cybersecurity maturity and selected information-security controls of SkyBridge Travel Services, a fictional travel-services organization of approximately 150 employees. It uses NIST CSF 2.0 and selected ISO/IEC 27001:2022 Annex A controls to identify gaps, assess risk and establish a prioritized remediation roadmap.

Six priority areas were assessed: identity and authentication, data classification, incident response, backup and recovery, security-policy governance, and centralized security monitoring. The assessment identified 3 Critical and 3 High inherent-risk findings. Average inherent risk is 17.5/25. Revised assumed residual risk averages 10.3/25, representing an average reduction of 7.2 points.

Residual-risk assumptions are differentiated by treatment effectiveness rather than applying one mechanical reduction to every finding. MFA receives the strongest direct likelihood reduction; governance receives a more modest reduction; monitoring and incident response primarily improve detection, containment and impact limitation; tested backups reduce recovery-related impact.

Metric	Result
Total findings	6
Critical / High inherent findings	3 / 3
Average inherent risk	17.5 / 25
Average residual risk	10.3 / 25
Average risk reduction	7.2 points
NIST CSF mapped	6 / 6
ISO 27001 mapped	6 / 6

The assessment is a simulated portfolio exercise. It is not an ISO/IEC 27001 certification audit, legal compliance determination, penetration test, or technical control validation.

2. Organization Context

SkyBridge Travel Services is a fictional emerging travel-services provider supporting business and individual customers. Its operating model includes travel bookings, itinerary management and customer support.

The organization uses cloud infrastructure, Microsoft 365, company-managed laptops, third-party service providers and remote/hybrid working arrangements. An AI customer-service agent is also used within operations. Payment-related processing is handled through external payment providers.

The environment contains customer and employee personal information, account credentials, booking and itinerary information, corporate identities, cloud workloads, security logs, backup infrastructure and third-party dependencies.

Business security priorities

Priority	Objective
Information security	Protect critical business systems and information from unauthorized access or disruption.
Payment security	Maintain secure and reliable processing of customer payments.
Data privacy	Protect customer and employee personal information.
Data management	Establish consistent processes for collecting, storing, using and disposing of information.
Compliance	Meet applicable legal, regulatory and contractual requirements.

3. Assessment Scope & Objectives

The assessment focuses on six priority cybersecurity areas selected to demonstrate an end-to-end maturity and ISMS assessment workflow.

Area	Assessment focus
Identity & access	MFA coverage and access-review practices.
Information classification	Classification of customer and employee information and associated handling requirements.
Incident response	Documented procedures, escalation and evidence preservation.
Backup & recovery	Existence of backups and evidence that restoration works.
Security governance	Policy approval, ownership and review cycle.
Security monitoring	Centralized logging, alert review and escalation.

Objectives

1. Assess cybersecurity control practices across the six selected priority areas.
2. Assess security policies and governance against applicable requirements and NIST CSF 2.0.
3. Identify cybersecurity risks, threats and control gaps.
4. Assess selected ISMS controls against ISO/IEC 27001:2022 Annex A.
5. Develop a prioritized remediation roadmap.

Scope boundary: Vulnerability management and the AI customer-service agent are recognized as potential future-phase assessment areas but are not part of this six-area review. This is a focused assessment rather than a complete assessment of every NIST CSF outcome or ISO/IEC 27001 requirement.

4. Methodology

The assessment follows a structured risk-and-control methodology. The fictional organization's business context and technology environment were established, followed by identification of relevant assets, threats, vulnerabilities and existing controls.

Each finding was scored using a 5×5 likelihood-impact model and mapped to relevant NIST CSF 2.0 outcomes and selected ISO/IEC 27001:2022 Annex A controls. A focused Statement of Applicability (SoA) was created for the six selected controls, followed by a prioritized remediation roadmap.

Analytical chain: Asset → Threat → Vulnerability/Gap → Risk → Existing Control → Treatment → Residual Risk

No real organizational systems were accessed or technically tested. Evidence and control states are simulated for portfolio purposes.

5. Risk Assessment Method

Risk is calculated as Likelihood × Impact, with each factor scored from 1 to 5. Inherent risk represents exposure before the proposed treatment; residual risk represents the assumed exposure after the recommended treatment is implemented.

Score	Likelihood	Impact
1	Rare	Negligible
2	Unlikely	Minor
3	Possible	Moderate
4	Likely	Major
5	Almost certain	Severe

Risk bands

Score	Rating
1–5	Low
6–10	Medium
11–15	High
16–25	Critical

Residual-risk calibration: residual scores are not mechanically set to one value. The assessment considers how directly each treatment affects the threat pathway. Impact is retained where the consequence of a successful event remains severe; impact is reduced only where the treatment plausibly limits consequence.

6. Executive Risk Dashboard

NIST Function	Finding	Inherent	Residual	Residual level
Govern	Security policy governance	15	15	High
Identify	Data classification	15	10	Medium
Protect	MFA coverage	20	5	Low
Detect	Centralized monitoring	20	12	High
Respond	Incident response	20	12	High
Recover	Backup restoration	15	8	Medium

Inherent risk distribution: 3 Critical and 3 High. Residual distribution after assumed treatment: 3 High, 2 Medium and 1 Low.

The revised residual profile reflects the different mechanisms of the treatments. MFA materially reduces the likelihood of credential-based compromise. Backup testing can reduce recovery failure likelihood and business impact. Incident response and monitoring improve containment, detection and impact limitation. Policy governance remains High because formal approval and review are important but have a weaker direct effect on attack likelihood.

7. Detailed Findings

Finding 1 — MFA Not Enforced for All Employees

Asset: Employee accounts / corporate systems

Threat: Account compromise

Vulnerability / Gap: MFA is enabled for administrators but is not mandatory for standard employee accounts; access reviews are informal.

Existing Control: MFA for administrator accounts

NIST CSF 2.0: Protect — PR.AA-03

ISO/IEC 27001:2022: A.8.5 — Secure authentication

Risk: $4 \times 5 = 20$ (Critical); residual: $1 \times 5 = 5$ (Low).

Recommended Treatment: Enforce MFA for all employee accounts and establish documented quarterly access reviews.

Residual-risk rationale: Full employee MFA materially reduces credential-only account compromise; impact remains severe because a compromised account could still access sensitive systems.

Finding 2 — No Formal Data Classification Scheme

Asset: Customer personal information / itineraries

Threat: Unauthorized access or disclosure

Vulnerability / Gap: Customer and employee information is stored in cloud systems without a formal classification policy defining sensitivity and handling requirements.

Existing Control: Basic access controls on cloud storage

NIST CSF 2.0: Identify — ID.AM-07

ISO/IEC 27001:2022: A.5.12 — Classification of information

Risk: $3 \times 5 = 15$ (High); residual: $2 \times 5 = 10$ (Medium).

Recommended Treatment: Define classification levels and corresponding handling, access, storage, retention and disposal requirements.

Residual-risk rationale: A formal classification and handling scheme reduces inappropriate exposure, but the underlying sensitivity and consequence of disclosure remain high.

Finding 3 — Incident Response Not Formally Documented

Asset: Security / IT environment

Threat: Unauthorized or malicious activity

Vulnerability / Gap: Suspicious events are investigated, but there is no formally documented procedure covering investigation, notification, containment, evidence preservation and escalation.

Existing Control: Informal monitoring, investigation and escalation

NIST CSF 2.0: Respond — RS.MA-04

ISO/IEC 27001:2022: A.5.24 — Incident management planning and preparation

Risk: $4 \times 5 = 20$ (Critical); residual: $3 \times 4 = 12$ (High).

Recommended Treatment: Create and approve an IR procedure, L1→L2 escalation path, severity criteria, evidence-preservation requirements and tabletop exercises.

Residual-risk rationale: Formal IR procedures improve escalation and containment, reducing the likelihood of prolonged compromise and limiting impact; they do not prevent every incident.

Finding 4 — Backup Restoration Has Not Been Tested

Asset: Backup systems / critical business data

Threat: Ransomware or system failure

Vulnerability / Gap: Cloud backups exist, but no evidence demonstrates that critical data can be successfully restored.

Existing Control: Cloud backup system

NIST CSF 2.0: Recover — RC.RP-02

ISO/IEC 27001:2022: A.8.13 — Information backup

Risk: $3 \times 5 = 15$ (High); residual: $2 \times 4 = 8$ (Medium).

Recommended Treatment: Document recovery procedures and perform periodic restoration tests for critical data.

Residual-risk rationale: Tested recovery procedures reduce the likelihood of failed recovery and lower business impact, but ransomware or major outage consequences can remain material.

Finding 5 — Security Policies Lack Formal Governance

Asset: Security policies / ISMS

Threat: Weak security governance

Vulnerability / Gap: Security policies exist but are not formally approved by senior management and lack a documented annual review cycle.

Existing Control: Security policies exist

NIST CSF 2.0: Govern — GV.PO-01 / GV.PO-02

ISO/IEC 27001:2022: A.5.1 — Policies for information security

Risk: $3 \times 5 = 15$ (High); residual: $3 \times 5 = 15$ (High).

Recommended Treatment: Establish management approval, policy ownership, version control and a documented annual review cycle.

Residual-risk rationale: Formal approval, ownership and review improve governance consistency, but they provide less direct reduction of attack likelihood or impact than technical controls.

Finding 6 — No Centralized Security Monitoring

Asset: Cloud systems / security logs

Threat: Unauthorized access / malicious activity

Vulnerability / Gap: Cloud security logs are collected and retained, but there is no centralized monitoring or routine security-log review.

Existing Control: Cloud logs collected and retained

NIST CSF 2.0: Detect — DE.CM-01

ISO/IEC 27001:2022: A.8.16 — Monitoring activities

Risk: $4 \times 5 = 20$ (Critical); residual: $3 \times 4 = 12$ (High).

Recommended Treatment: Implement centralized SIEM or managed SOC monitoring, with defined alert review, escalation and monitoring responsibilities.

Residual-risk rationale: Centralized monitoring improves early detection and response, reducing the likelihood of prolonged malicious activity and limiting impact; it does not prevent attacks by itself.

8. NIST CSF 2.0 Assessment

Finding	Function	Category	Subcategory
MFA gap	Protect	PR.AA	PR.AA-03
Data classification gap	Identify	ID.AM	ID.AM-07
Incident-response gap	Respond	RS.MA	RS.MA-04
Backup restoration gap	Recover	RC.RP	RC.RP-02
Policy governance gap	Govern	GV.PO	GV.PO-01 / GV.PO-02
Monitoring gap	Detect	DE.CM	DE.CM-01

The data-classification finding uses ID.AM-07 rather than ID.AM-05 because the gap concerns maintaining information inventories/metadata and applying classification to designated data types. ID.AM-05 concerns prioritizing assets based on classification, criticality, resources and mission impact.

NIST CSF mappings identify relevant cybersecurity outcomes; they do not by themselves establish that the organization is compliant or certified.

9. ISO/IEC 27001:2022 Gap Assessment

The assessment uses six selected Annex A controls to demonstrate an ISMS gap-assessment approach. It is not a full ISO/IEC 27001 assessment.

Control	Status	Primary Gap / Action
A.8.5 — Secure authentication	Partially implemented	MFA is admin-only; enforce MFA for all employees.
A.5.12 — Classification of information	Not implemented	Create formal classification scheme and handling requirements.
A.5.24 — Incident management planning and preparation	Partially implemented	Formalize, approve and test incident response.
A.8.13 — Information backup	Partially implemented	Test restoration of critical data.
A.5.1 — Policies for information security	Partially implemented	Formal management approval and annual review.
A.8.16 — Monitoring activities	Partially implemented	Centralized monitoring, alert review and escalation.

10. NIST CSF 2.0 ↔ ISO/IEC 27001:2022 Crosswalk

#	Finding	NIST CSF 2.0	ISO 27001:2022 Annex A	Remediation
1	MFA gap	PR.AA-03	A.8.5	Enforce MFA
2	Data classification gap	ID.AM-07	A.5.12	Implement classification policy
3	Incident response gap	RS.MA-04	A.5.24	Document and test IR
4	Backup restoration gap	RC.RP-02	A.8.13	Test restoration
5	Policy governance gap	GV.PO-01 / GV.PO-02	A.5.1	Management approval + review cycle
6	Monitoring gap	DE.CM-01	A.8.16	Implement SIEM/SOC monitoring

11. Statement of Applicability

The following focused SoA covers only the six controls selected for this portfolio assessment. All six are considered applicable to SkyBridge's simulated environment.

Control	Applicable	Status	Rationale / Gap
A.8.5 — Secure authentication	Yes	Partially implemented	Business accounts require strong authentication; MFA coverage is incomplete.
A.5.12 — Classification of information	Yes	Not implemented	Customer and employee information requires classification and handling rules.
A.5.24 — Incident management planning and preparation	Yes	Partially implemented	Events are investigated informally but formal planning is absent.
A.8.13 — Information backup	Yes	Partially implemented	Backups exist but restoration has not been demonstrated.
A.5.1 — Policies for information security	Yes	Partially implemented	Policies exist without formal approval/review governance.
A.8.16 — Monitoring activities	Yes	Partially implemented	Logs exist without centralized monitoring and routine review.

A complete ISO/IEC 27001 Statement of Applicability would require consideration of the full set of necessary controls and documented inclusion/exclusion rationales. This focused SoA is a portfolio baseline, not a complete organizational SoA.

12. Prioritized Remediation Roadmap

Priority	Finding	Risk	Timeframe	Owner	Success Criteria
1	MFA gap	20 / Critical	0–30 days	IT / Security	100% employee accounts enrolled in MFA
2	Incident-response gap	20 / Critical	0–30 days	CISO / Security	Approved IR procedure + tabletop exercise
3	Centralized monitoring gap	20 / Critical	0–30 days	Security / SOC	Critical systems centrally monitored with documented alert review
4	Data classification gap	15 / High	31–60 days	CISO / Security + Data Owners	Approved policy + documented information categories
5	Backup restoration gap	15 / High	31–60 days	IT / Infrastructure	Successful documented restoration test
6	Policy governance gap	15 / High	31–60 days	CISO / Senior Management	Policies approved + review schedule documented

The roadmap is prioritized using inherent risk and business urgency, not residual risk. Residual risk is an outcome estimate used to test whether the proposed treatments provide a plausible reduction in exposure.

13. Conclusion

SkyBridge Travel Services has the beginnings of a cybersecurity control environment, including administrator MFA, cloud access controls, security-event investigation, cloud backups, security policies and log collection. However, several controls are not yet consistently documented, broadly enforced, centrally monitored or tested.

The most significant priorities are identity protection, incident-response readiness and security monitoring. The remaining findings—data classification, backup restoration testing and security-policy governance—provide the foundation for a more mature and repeatable ISMS.

The revised residual-risk model strengthens the assessment by distinguishing between treatments. Technical and operational controls that directly change the threat pathway receive stronger reductions, while governance controls receive more modest reductions.

14. Assessment Limitations

1. SkyBridge Travel Services is a fictional organization created for portfolio purposes.
2. The assessment covers six selected control areas rather than the complete NIST CSF 2.0 Core or all ISO/IEC 27001 requirements and Annex A controls.
3. No penetration testing, vulnerability scanning, configuration review or technical validation was performed.
4. Evidence and control states are simulated and were not independently verified.
5. Likelihood and impact ratings are analytical estimates for the scenario and should be recalibrated using organizational risk appetite and actual evidence.
6. Residual-risk scores are assumed outcomes after recommended treatment and are not measured post-implementation results.
7. Vulnerability management and the AI customer-service agent were identified as future-phase assessment areas and deliberately excluded from this six-area review.
8. The assessment does not provide an ISO/IEC 27001 certification opinion, legal compliance determination or assurance over third-party providers.

Final assessment statement: This report demonstrates a structured cybersecurity maturity and ISMS gap-assessment methodology using NIST CSF 2.0 and selected ISO/IEC 27001:2022 Annex A controls. It should be presented as a simulated portfolio project and not as evidence of an external audit or certification.